

Date : LIRT 2025/2026

CHAPITRE 2 – HARDENING & VULNERABILITY MANAGEMENT

TP 2.3 – ALTERNATIVE PROFESSIONNELLE GRATUITE: OpenVAS

1. Introduction

Dans un contexte actuel marqué par une augmentation constante des cyberattaques, la sécurité des systèmes informatiques est devenue une priorité majeure. L'une des premières étapes pour sécuriser un système consiste à **identifier ses vulnérabilités** avant qu'elles ne soient exploitées par des attaquants.

Ce TP porte sur l'utilisation de deux outils de scan de vulnérabilités largement utilisés :

- Nessus (solution propriétaire)
- OpenVAS / GVM (solution open-source)

L'objectif principal est d'analyser la sécurité de systèmes Linux et Windows, d'identifier les failles existantes, puis de comparer les résultats obtenus afin d'évaluer leur niveau de sécurité.

2. Objectifs du TP

Objectif général

Mettre en œuvre des outils de scan de vulnérabilités afin d'évaluer la sécurité d'un système informatique.

Objectifs spécifiques

À l'issue de ce TP, nous devons être capables de :

- Installer et configurer OpenVAS (GVM)
 - Utiliser Nessus pour effectuer des analyses de sécurité
 - Réaliser des scans sur des machines Linux et Windows
 - Identifier les vulnérabilités (CVE)
 - Analyser les risques associés
 - Proposer des solutions de correction
 - Comparer les résultats avant et après correction
 - Comparer les performances de Nessus et OpenVAS
-

3. Présentation des outils

3.1 Nessus

Nessus est un scanner de vulnérabilités développé par l'entreprise Tenable.

Fonctionnalités principales :

- Interface graphique simple et intuitive
- Détection automatique des vulnérabilités
- Génération de rapports détaillés et exploitables
- Large adoption en entreprise

Limite :

- Version complète payante (licence professionnelle)
-

3.2 OpenVAS (GVM)

OpenVAS (Open Vulnerability Assessment System), intégré dans GVM, est une solution opensource de gestion des vulnérabilités.

Fonctionnalités principales :

- Gratuit et open-source
- Analyse approfondie des vulnérabilités
- Utilisation de bases de données reconnues (CVE, SCAP, NVT)
- Adapté aux environnements professionnels et académiques

Limites :

- Installation complexe
 - Configuration technique
 - Synchronisation des bases parfois longue
-

4. Installation et configuration d'OpenVAS

Installation

```
sudo apt update && sudo apt upgrade -y sudo  
apt install gvm -y
```

Initialisation et démarrage

```
sudo gvm-setup
```

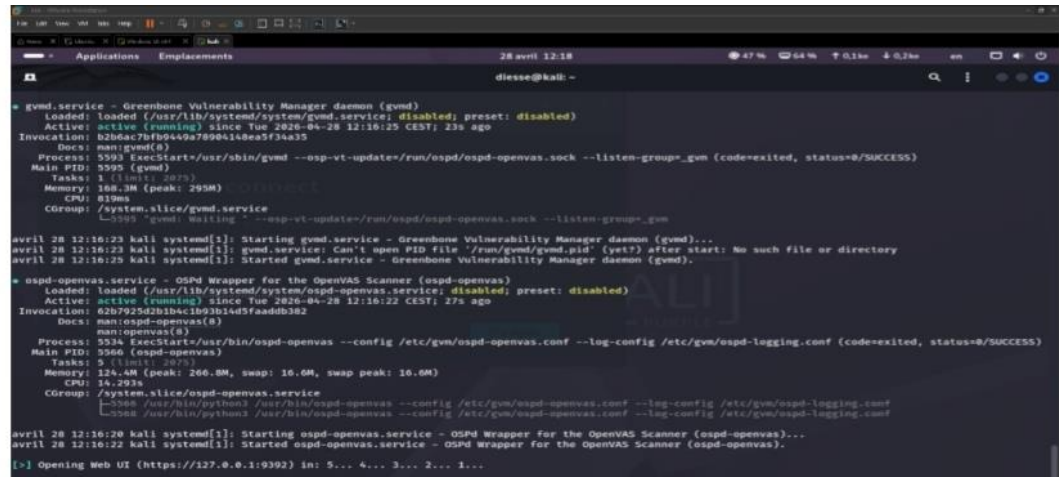
sudo gvm-start

Synchronisation des bases

sudo greenbone-feed-sync --type GVMMD_DATA sudo

greenbone-feed-sync --type SCAP

sudo greenbone-feed-sync --type CERT



```
gvm.service - Greenbone Vulnerability Manager daemon (gvmd)
Loaded: loaded (/usr/lib/systemd/system/gvm.service; disabled; preset: disabled)
Active: active (running) since Tue 2024-04-28 12:16:23 CEST; 23s ago
Invocation: 62b6ae77bf05a9a7890414be5f34a35
Docs: man:gvm(8)
Process: 5593 ExecStart=/usr/sbin/gvmd --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=gvm (code=exited, status=0/SUCCESS)
Main PID: 5595 (gvmd)
Tasks: 1 (limit: 2073)
Memory: 148.2M (peak: 293M)
CPU: 819ms
CGroup: /system.slice/gvm.service
└─5595 "gvmd: waiting" --osp-vt-update=/run/ospd/ospd-openvas.sock --listen-group=gvm

avril 28 12:16:23 kali systemd[1]: Starting gvm.service - Greenbone Vulnerability Manager daemon (gvm)...
avril 28 12:16:23 kali systemd[1]: gvm.service: Can't open PID file /run/gvm/gvm.pid' (yet?) after start: No such file or directory
avril 28 12:16:25 kali systemd[1]: Started gvm.service - Greenbone Vulnerability Manager daemon (gvm).

ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas)
Loaded: loaded (/usr/lib/systemd/system/ospd-openvas.service; disabled; preset: disabled)
Active: active (running) since Tue 2024-04-28 12:16:22 CEST; 27s ago
Invocation: 62b7925d2b1b4c1b93b1u5faadb382
Docs: man:ospd-openvas(8)
Process: 5534 ExecStart=/usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf (code=exited, status=0/SUCCESS)
Main PID: 5566 (ospd-openvas)
Tasks: 2 (limit: 2073)
Memory: 124.4M (peak: 266.0M, swap: 10.0M, swap peak: 10.0M)
CPU: 14.293s
CGroup: /system.slice/ospd-openvas.service
└─5566 /usr/bin/python3 /usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf
└─5568 /usr/bin/python3 /usr/bin/ospd-openvas --config /etc/gvm/ospd-openvas.conf --log-config /etc/gvm/ospd-logging.conf

avril 28 12:16:20 kali systemd[1]: Starting ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas)...
avril 28 12:16:22 kali systemd[1]: Started ospd-openvas.service - OSPd Wrapper for the OpenVAS Scanner (ospd-openvas).
[+] Opening Web UI (https://127.0.0.1:9302) in: 5... 4... 3... 2... 1...
```

:

5. Méthodologie de scan

Les analyses ont été réalisées sur deux machines :

- Machine Linux (Ubuntu Server)
- Machine Windows 10

Étapes détaillées

1. Création de la cible

- Aller dans : Configuration → Targets ☐ Cliquer sur : New Target
- Saisir l'adresse IP de la machine cible
- Valider avec Create

New Target

×

Name

ubuntu&windows

Comment

Hosts

☒ Manual

192.168.56.10;192.168.56.20

2. Configuration du scan

- Aller dans : Scans → Tasks  Cliquer sur : New Task  Choisir :
 - La cible
 - Le profil : *Full and Fast*
- Lancer la tâche

New Task

×

Name

TP_2.3

Comment

Scan Targets

ubuntu&windows

⌵

+

Alerts

⌵

+

Schedule

—

⌵

☐ Once

+

Add results to Assets

☒ Yes
☐ No

Apply Overrides

☒ Yes
☐ No

Min QoD

70

⌵

Alterable Task

Cancel

Save

3. Lancement du scan

- Démarrer l'analyse en cliquant sur *Start*

4. Collecte des résultats

- Aller dans : Scans → Reports
- Consulter et exporter les résultats

6. Résultats des scans

6.1 Analyse du système Linux

L'analyse du système Linux (Ubuntu) montre un niveau de sécurité globalement satisfaisant.

Résultats observés :

- Présence de ports ouverts nécessaires (SSH 22, HTTP 80)
- Nombre limité de vulnérabilités détectées
- Majorité de vulnérabilités faibles à moyennes
- Absence de vulnérabilités critiques
- Quelques CVE avec impact faible



Interprétation

Ces résultats indiquent que :

- Le système est régulièrement mis à jour
- Les services sont correctement configurés
- La surface d'attaque est limitée

☞ Cela correspond à un système bien administré.

6.2 Analyse du système Windows

L'analyse du système Windows révèle un niveau de vulnérabilité beaucoup plus élevé.

Résultats observés :

- Grand nombre de vulnérabilités détectées

- Présence importante de vulnérabilités critiques
- Exposition de services sensibles (ex : SMB port 445)
- Présence de nombreuses CVE non corrigées
- Failles liées au système et aux services réseau



Interprétation

Le système Windows présente :

- Une surface d'attaque importante □ Un manque de mises à jour
- Des services critiques exposés

☞ Ce type de système est facilement exploitable par un attaquant.

7. Analyse des vulnérabilités

Les vulnérabilités sont évaluées selon plusieurs critères :

CVE (Common Vulnerabilities and Exposures)

Identifiant unique de chaque faille de sécurité.

Niveaux d'impact :

- Faible : impact limité
- Moyen : exploitation possible
- Élevé : accès non autorisé
- Critique : contrôle total du système

Types d'exploitation possibles :

- Exécution de code à distance
- Vol de données
- Escalade de privilèges

- Compromission du système

8. Corrections appliquées

Les actions mises en œuvre pour sécuriser les systèmes sont :

- Mise à jour des systèmes
- Fermeture des ports inutiles
- Désactivation des services vulnérables
- Application des correctifs de sécurité

9. Comparaison avant / après

Avant correction :

- Nombre élevé de vulnérabilités
- Système fortement exposé
- Risque critique élevé

Après correction :

- Réduction significative des vulnérabilités
- Système plus sécurisé
- Risque maîtrisé

10. Comparaison Nessus vs OpenVAS

Critère	Nessus	OpenVAS
Type	Propriétaire	Open-source
Installation	Facile	Complexe
Interface	Intuitive	Technique
Rapidité	Très rapide	Moyenne
Détails	Bon	Très détaillé
Coût	Payant	Gratuit

11. Analyse professionnelle

Nessus est particulièrement adapté aux entreprises grâce à :

- sa simplicité d'utilisation □ sa rapidité d'exécution
- la clarté de ses rapports

OpenVAS constitue une alternative puissante mais plus technique, adaptée aux environnements académiques ou aux experts.

12. Réponse finale

Quel outil est le plus adapté en entreprise ?

Réponse : Nessus Justification

:

- Facilité d'utilisation □ Gain de temps
- Rapports professionnels
- Support technique
- Standard en entreprise

13. Conclusion

Ce TP a permis de comprendre l'importance des outils de scan de vulnérabilités dans une stratégie de cybersécurité.

Il met en évidence que :

- Nessus est une solution efficace et adaptée au monde professionnel
- OpenVAS est une alternative gratuite mais plus complexe

☞ L'utilisation combinée de ces outils permet d'obtenir une vision complète de la sécurité d'un système.
